KOLEJ PROFESIONAL MARA BERANANG

KOLEJ PROFESIONAL MARA INDERA MAHKOTA

DIPLOMA IN COMPUTER SCIENCE

COURSE NAME	:	CYBERSECURITY FUNDAMENTALS
COURSE CODE	:	CSC 2863
ACADEMIC SESSION	:	2 2026/2027
TYPE OF ASSESSMENT	:	FINAL ASSIGNMENT
DURATION	:	12 OCT 2026 – 03 NOV 2026 (2 WEEKS)

CLO3: Propose information assurance to overcome cybersecurity threats.

INSTRUCTIONS TO CANDIDATES:

1. Late submissions after the given due date will not be accepted.
2. Report should be written using:
   a. Font type: Arial
   b. Size: 11 pts
   c. Line Spacing: 1.5

Personal Details	
Name	
I/D Number	
Class	
Lecturer	

Section / Question No.	**Marks**
1	
2	
3	
4	
Total	**/ 40**

I hereby declare that no form of plagiarism will be tolerated in this assessment. Failure to comply will result in a failing grade for the assessment.

Signature: _____ Date: _____

Scenario:

LestariNw Sdn. Bhd. is a medium-sized company with approximately 120 employees. The company manages customer information, financial records, employee information, and internal business documents through its company network. The CEO of the company plans to have mobile workers and Small Office Home Office (SOHO) arrangements for several departments in the company. Mobile workers and remote workers are able to access company systems from their homes and other external locations using laptops and personal devices.

However, the company's existing network security arrangement was designed mainly for employees working inside the office. The management has identified several security problems including:

1. Employees access company systems through public and home Wi-Fi networks without a consistent secure remote access mechanism.
2. Some employees use personal laptops and devices to access company information. The security configuration of these devices is not controlled consistently by the company.
3. Remote employees currently connect to the company network using different methods. There is no standard remote access security control implemented across the organisation.
4. The company's internal network is not sufficiently segmented. A user who successfully gains unauthorised access to one part of the network may potentially reach other internal resources.
5. The company currently has limited monitoring of suspicious network activities. Management is concerned that an attack may not be detected quickly.
6. Important company services depend on several critical network components. If one critical component fails, some services may become unavailable.
7. The company does not have a clear security policy, standard and procedure specifically governing secure remote access.

The management is therefore planning to improve the company's network security before continuing the SOHO arrangement. The possible network security defence that is suitable to the company are:

- Virtual Private Network (VPN)
- Internet Protocol Security (IPsec)
- Secure Shell (SSH)
- Secure Socket Layer / Transport Layer Security (SSL/TLS)
- Intrusion Detection System (IDS)
- Intrusion Prevention System (IPS)

Next, you must propose two (2) different network architecture designs that show how the technology will be used in the company environment. To protect the business network from potential attacks, your architecture should identify the main network components, communication flows, security zones and the location of the chosen security control.

You are also expected to analyse and assess the potential risks that may occur by applying the Risk Management Cycle (RMC). Provide detailed steps on how the company's overall IT security posture can be improved based on your risk assessment.

In addition, you are required to propose a security policy, a supporting security standard and a security procedure (guidelines) about your network defence technology tool above. The policy should establish the security requirements; the standard should define the technical and operational requirements supporting the policy and the procedure should provide step-by-step guidance for implementation and compliance.

Task 1: Selection of network defence

Justify **one (1)** suitable network defence technology that can be implemented to secure the remote company network. Your justification must include:

- identify the selected network defence technology;
- explain its purpose and security function;
- explain how the technology protects the company's remote network; and
- justify why the selected technology is appropriate based on the company scenario, network requirements, and potential security threats.

Task 2: Network Architecture Design

Propose any **two (2)** network architecture designs that illustrate how the selected network defence technology from Task 1 can be implemented within the company environment. For each proposed design:

- illustrate the network architecture using a suitable network diagram;
- identify the major network components involved;
- indicate where the selected defence technology will be deployed; and
- explain how the design improves the security of the company's remote network.

Your proposed designs should demonstrate different approaches to implementing the selected technology and should be relevant to the company scenario.

Task 3: Risk Management Cycle (RMC)

Propose a Risk Management Cycle (RMC) for one (1) potential risk associated with the network defence technology selected in Task 1.

Your RMC must address the following:

- Risk Identification: Identify and describe one potential risk or vulnerability that may affect the selected network defense technology.
- IT Risk Assessment: Assess the identified risk by considering its likelihood, impact, and overall risk level to the company.
- Risk Response and Mitigation: Propose appropriate controls or mitigation strategies to reduce the identified risk.
- Risk Monitoring and Reporting: Propose how the identified risk should be continuously monitored, documented, and reported to the appropriate personnel.

Task 4: Organizational Security Policy

Propose a clear security policy, standard (supporting the policy details) and procedure (guidelines) of component of network defence technology based on Task 1.

Security Policy	Security Standard	Security Procedure
Propose a clear and ethical security policy document covering purpose, scope, policy details, enforcement, users and responsibilities.	Propose a security standard that supports and strengthens the security policy developed in Task 4(a) based on a recognised IT or cybersecurity standard/framework, such as ISO/IEC 27001, NIST, or another relevant security standard.	Develop a security procedure that provides practical guidelines for implementing and maintaining the security policy and standards.

TASK 1: SELECTION OF NETWORK DEFENCE TECHNOLOGY

1.1 Introduction to the Selected Network Defence Technology

The selected network defence technology for LestariNw Sdn. Bhd. is an **Intrusion Prevention System (IPS)**. IPS is a network security technology designed to monitor network traffic, identify suspicious activities and automatically prevent potential threats from entering or affecting a protected network. It works by inspecting network packets and analysing their patterns to determine whether the traffic is legitimate or potentially harmful. When suspicious or malicious traffic is detected, IPS can take immediate action, such as dropping harmful packets or blocking the connection to prevent the attack from reaching the network.

IPS can use different detection techniques, including signature-based detection and anomaly-based detection, to identify known attacks and unusual network behaviour. It is commonly deployed inline within a network, allowing it to inspect traffic as it passes through the system and prevent detected threats in real time.

This technology is relevant to LestariNw Sdn. Bhd. because the company plans to allow employees to access internal resources remotely through home networks, public Wi-Fi and personal devices. These external connections may increase the risk of malicious activities and unauthorised access to company resources. Therefore, implementing IPS can provide an additional layer of network protection by continuously monitoring traffic and preventing detected threats before they affect the company's systems and sensitive information.

1.2 Purpose and Security Functions of IPS

The main purpose of IPS is to detect and prevent malicious network activities before they can affect the company's systems. The following are the most relevant security functions of IPS:

a) Network Traffic Monitoring

IPS continuously monitors network traffic entering and leaving the network. It inspects data packets to identify suspicious connections and unusual activities that may indicate a security threat.

b) Intrusion Detection

IPS uses signature-based detection to identify known attacks by comparing network traffic with recognised attack patterns. It also uses anomaly-based detection to identify unusual network behaviour that may indicate a potential threat.

c) Automatic Threat Prevention

When malicious traffic is detected, IPS can automatically take action by dropping suspicious packets or blocking harmful connections. This helps prevent attackers from accessing or damaging the company's network.

d) Security Logging and Alert Generation

IPS records detected security incidents and generates alerts for network administrators. These records help administrators monitor network activities, investigate suspicious incidents and identify potential security problems.

1.3 How IPS Protects the Company's Remote Network

LestariNw Sdn. Bhd. allows employees to access company resources from **external locations**, such as their homes and public Wi-Fi networks. These connections may expose the company to security threats, particularly when employees use personal devices with **inconsistent security configurations**.

IPS can protect the company's remote network by **inspecting network traffic before it reaches internal company resources**. For example, employees can first connect to the company network through a **Virtual Private Network (VPN)**, which provides an encrypted connection for remote access. The traffic can then pass through the firewall and an **inline IPS** before reaching the internal network.

The IPS examines the traffic for **suspicious activities and known attack patterns**. If malicious traffic is detected, the IPS can **block the connection or drop harmful packets** to prevent the threat from reaching company systems.

For example, if an attacker attempts to exploit a vulnerability in a company server containing customer information, the IPS can detect the suspicious traffic and **block the attack**. This reduces the risk of **unauthorised access and data exposure**.

IPS can also monitor traffic between different network segments to provide additional protection for important company resources. However, IPS does not replace **VPN encryption or user authentication**. Therefore, it should be used together with VPN, firewall and other security controls to provide stronger protection for remote access.

1.4 Justification for Selecting IPS

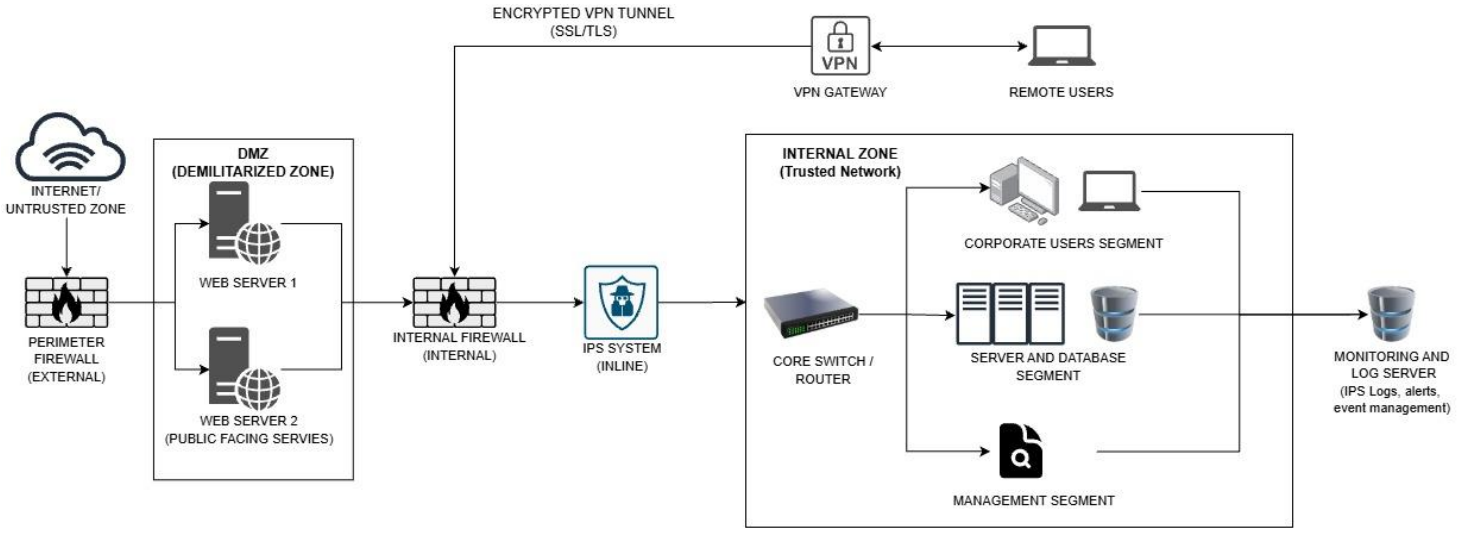
IPS is suitable for LestariNw Sdn. Bhd. because it addresses the **security weaknesses identified in the scenario**. The company currently has limited monitoring of suspicious network activities. By implementing IPS, the company can **continuously monitor network traffic, detect potential threats and automatically block malicious connections**. This improves the company's ability to respond to network attacks.

Furthermore, employees are allowed to access company resources using **personal devices and external networks**. These devices may have inconsistent security configurations, increasing the possibility of malware infections and suspicious network connections. IPS provides an additional layer of protection by **inspecting traffic before it reaches the company's internal network**.

The company also handles **sensitive information**, including customer details, financial records, employee information and internal documents. A successful network attack could affect the **confidentiality, integrity and availability** of this information. IPS helps reduce this risk by preventing detected malicious activities. Therefore, IPS is an appropriate choice for strengthening LestariNw Sdn. Bhd.'s network security, particularly when combined with **VPN, firewall and proper network segmentation**.

TASK 2: PROPOSED NETWORK ARCHITECTURE DESIGNS

2.1 Design 1: Defense-in-Depth Network Security Architecture



This architecture applies a defense-in-depth approach by using multiple security layers, including a perimeter firewall, DMZ, internal firewall and Intrusion Prevention System (IPS). Each security layer provides additional protection to the company's network and sensitive resources.

Major Network Components

Component	Description
Internet / Untrusted Zone	External network that may contain potential security threats.
Perimeter Firewall	Filters and blocks unwanted traffic from the Internet based on security policies.
DMZ (Demilitarized Zone)	A separate network zone that hosts public-facing services, such as web servers, if required.
Internal Firewall	Controls and restricts traffic entering the internal network from the DMZ.
VPN Gateway	Provides secure and encrypted remote access for employees.
IPS	Inspects network traffic and automatically detects and blocks malicious activities.
Core Switch / Router	Routes and forwards legitimate traffic to internal network segments.
Internal Network Segments	Separates corporate users, servers and databases, and management resources.

Explanation of the Design

In this architecture, remote employees connect to the company network through an encrypted VPN tunnel using the VPN gateway. This provides secure remote access when employees use home or public Wi-Fi networks.

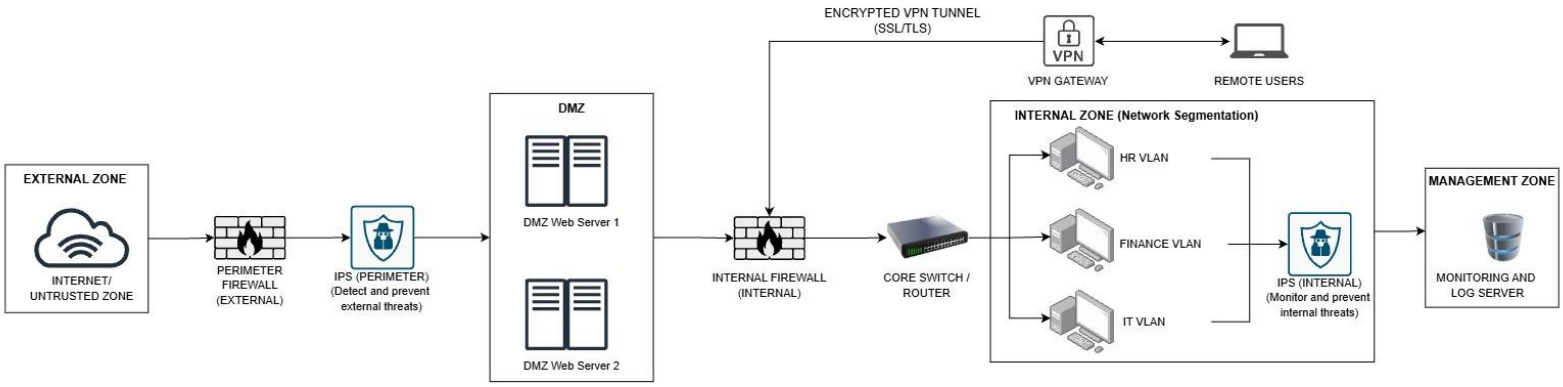
External traffic first passes through the perimeter firewall, which filters incoming connections based on predefined security policies. Public-facing services, if required, are placed within the DMZ to separate them from the internal company network.

The internal firewall controls traffic moving from the DMZ towards the internal network. An IPS is deployed inline after the internal firewall to inspect traffic before it reaches the core switch and internal network segments. If malicious activities are detected, the IPS automatically blocks the traffic.

The internal network is divided into separate segments for corporate users, servers and databases, and management resources. This separation helps reduce unnecessary access to sensitive company information. Security logs and alerts can also be collected for monitoring and further investigation.

This design improves network security by providing multiple layers of protection. Even if an external threat passes the perimeter firewall or compromises a service in the DMZ, the internal firewall and IPS provide additional protection for the company's internal resources.

2.2 Design 2: Distributed IPS Architecture



This architecture uses multiple IPS deployment points to provide distributed protection across different network zones. One IPS is deployed at the network perimeter to inspect external traffic, while another IPS is deployed within the internal network to monitor traffic between internal network segments and critical company resources.

Major Network Components

Component	Description
Internet / Untrusted Zone	External network that may contain potential security threats.
Perimeter Firewall	Filters and controls incoming traffic from the Internet.
DMZ	Hosts public-facing services separately from the internal network.
Perimeter IPS	Inspects and blocks malicious external traffic before it enters the internal network.
Internal Firewall	Controls traffic between the DMZ and internal network.
Core Switch / Router	Connects and routes traffic between different internal network segments.
HR VLAN	Separates HR systems and employee information.
Finance VLAN	Separates financial systems and confidential financial records.
IT VLAN	Separates IT resources and administrative systems.
Internal IPS	Monitors internal network traffic and prevents threats from reaching critical resources.
VPN Gateway	Provides secure and encrypted remote access for employees.
Monitoring and Log Server	Collects and stores security logs and alerts from IPS devices for monitoring and investigation.

Explanation of the Design

In this architecture, remote employees establish encrypted connections to the company network through a VPN gateway. The VPN gateway authenticates users and protects data transmitted over external networks.

The VPN gateway must be connected to the remote employees through an encrypted VPN tunnel to ensure that remote access traffic enters the company network through a controlled and secure connection.

Incoming traffic passes through the perimeter firewall, which filters network connections based on security policies. The perimeter IPS then inspects the traffic and automatically blocks malicious activities before they enter the internal network.

The network is divided into different security zones, including the external zone, DMZ, internal zone and management zone. Within the internal zone, VLANs are used to separate HR, Finance and IT departments. Access between these VLANs is controlled through firewall rules or Access Control Lists (ACLs).

An additional internal IPS is deployed inline on the traffic path to critical company resources, such as servers and databases. It monitors internal traffic and helps prevent threats originating from compromised devices or other network segments from reaching sensitive information.

Both IPS devices send security logs and alerts to a central monitoring and log server. This allows the IT security team to monitor suspicious activities, investigate potential incidents and respond to threats more effectively.

This design improves network security by providing multiple IPS protection points, network segmentation and centralised security monitoring. It helps protect both external connections and internal company resources.

2.3 Comparison of the Proposed Network Architecture Designs

Criteria	Design 1: Defense-in-Depth	Design 2: Distributed IPS
Main Approach	Uses multiple security layers, including firewalls, DMZ and IPS.	Uses multiple IPS deployment points and network segmentation.
IPS Deployment	One main IPS within the internal network boundary.	Multiple IPS devices at the perimeter and internal network.
Network Segmentation	Separates DMZ and internal network segments.	Uses multiple security zones and HR, Finance and IT VLANs.
Security Monitoring	Monitors internal traffic through the IPS.	Monitors external and internal traffic through multiple IPS devices.
Security Level	Provides layered network protection.	Provides distributed protection and broader monitoring coverage.
Cost and Maintenance	Moderate cost and easier to manage.	Higher cost and more complex to maintain.
Resource Requirements	Requires one main IPS deployment and firewall configuration.	Requires multiple IPS devices, VLAN configuration and centralised monitoring.
Limitations	Limited internal traffic inspection because only one main IPS is deployed.	Higher implementation cost and more complex management due to multiple IPS devices.
Suitability	Suitable for organisations requiring layered protection and isolated public-facing services.	Suitable for organisations requiring stronger monitoring, segmentation and internal traffic control.

2.4 Recommended Network Architecture

Design 2: Distributed IPS Architecture is recommended for LestariNw Sdn. Bhd. because the company handles sensitive customer, financial and employee information.

Multiple IPS devices provide additional protection by inspecting external and internal network traffic. VLAN segmentation also separates HR, Finance and IT resources, reducing unnecessary access between departments.

Centralised monitoring allows the IT security team to review IPS logs, identify suspicious activities and respond to potential threats. Regular IPS updates are also necessary to maintain effective protection.

Although this design requires higher implementation and maintenance costs, it provides stronger network security and better protection for the company's remote access environment. Therefore, it is the most suitable design for LestariNw Sdn. Bhd.

TASK 3: RISK MANAGEMENT CYCLE (RMC)

The Risk Management Cycle (RMC) is a process used to identify, assess, prioritise, treat and monitor potential risks that may affect an organisation. For LestariNw Sdn. Bhd., the RMC is applied to one potential risk associated with the selected Intrusion Prevention System (IPS).

3.1 Risk Identification

Identified Risk: Outdated IPS Signature Database

An Intrusion Prevention System (IPS) uses signature-based detection to identify known threats by comparing network traffic with stored attack patterns. These signatures must be updated regularly to ensure that the IPS can recognise the latest known threats.

If the IPS signature database is outdated, the system may fail to recognise certain malicious activities because the required attack signatures are not available. Consequently, malicious traffic may bypass the IPS and reach the company's internal network.

This risk is relevant to LestariNw Sdn. Bhd. because employees access company resources remotely through home networks, public Wi-Fi and personal devices. If an attacker uses an attack pattern that is not recognised by the outdated IPS signatures, the attack may reach internal systems and affect sensitive company information.

Risk Identification Details

Element	Description
Asset	Intrusion Prevention System (IPS) and internal company network.
Threat	Attackers sending malicious network traffic using attack patterns that are not recognised by the IPS.
Vulnerability	Outdated IPS signature database due to failure to perform regular updates.
Risk	The IPS may fail to detect and block malicious network traffic.
Possible Consequences	Unauthorised access, exposure of sensitive information and disruption of company services.
Risk Owner	IT Security Manager / Network Administrator.

3.2 IT Risk Assessment

The identified risk is assessed based on its likelihood and severity. The assessment follows the risk evaluation method from the lecture slides, where the risk score is calculated by multiplying the likelihood score by the severity score.

Risk Score = Likelihood × Severity

A. Likelihood Assessment

Likelihood measures how often or how likely a risk may occur. The following scale is based on the risk management lecture slides.

Score	Level	Description
5	Critical	Risk almost always occurs.
4	High	Risk often occurs.
3	Moderate	Risk occurs several times within the assessment period.
2	Low	Risk rarely occurs.
1	Extremely Low	Risk is very unlikely to occur.

Selected Likelihood: 3 (Moderate)

The likelihood is rated **3 (Moderate)** because IPS signature updates may be missed if the organisation does not perform regular update checks. LestariNw Sdn. Bhd. currently has limited monitoring of suspicious network activities, which may make it more difficult to identify problems with security monitoring and protection.

This rating is an assessment estimate because the scenario does not provide actual IPS update records or previous incident frequencies. The company should verify the rating using its update history and security logs.

B. Severity Assessment

Severity measures how serious the consequences could be if the identified risk occurs. The following scale follows the severity levels in the lecture slides.

Score	Level	Description
4	Critical	Extremely serious damage affecting important hardware and IT infrastructure.
3	High	Serious damage or compromise involving important systems or information.
2	Moderate	Data corruption or other significant data-related problems.
1	Low	Minor information security impact.

Selected Severity: 3 (High)

The severity is rated **3 (High)** because malicious traffic that bypasses the IPS could reach the company's internal systems. This may expose customer information, financial records, employee information and internal business documents. Such an incident could affect the confidentiality, integrity and availability of company information and disrupt business operations.

C. Risk Score Calculation

The overall risk score is calculated using the likelihood and severity ratings.

Assessment Criteria	Selected Rating	Score
Likelihood	Moderate	3
Severity	High	3
Risk Score: 3 × 3 = 9		

D. Risk Level Classification

The calculated score is compared with the risk classification table from the lecture slides.

Risk Score	Risk Level	Risk Criteria
1–4	Low	Acceptable, but should be observed.
5–7	Moderate	Must be monitored regularly.
8–11	High	Unacceptable without appropriate risk treatment.
12 and above	Critical	Unacceptable risk exposure requiring treatment.

Overall Risk Level: HIGH (Score: 9)

The identified risk is classified as **HIGH** because an outdated IPS signature database may prevent the system from recognising malicious network traffic. If an attack bypasses the IPS, sensitive company information and important business services may be affected.

According to the risk criteria, a high-level risk requires risk treatment. Therefore, LestariNw Sdn. Bhd. must implement appropriate mitigation strategies to ensure that the IPS signature database remains updated and effective.

3.3 Risk Response and Mitigation

Based on the risk assessment, the appropriate risk treatment for this issue is **Risk Mitigation**. Risk mitigation aims to reduce the likelihood of the risk occurring and minimise its potential consequences. The following preventive and corrective actions are proposed for LestariNw Sdn. Bhd.

Type of Action	Risk Mitigation Strategy
Preventive Action	Enable automatic IPS signature updates or establish a regular update schedule to ensure that the signature database remains current.
Preventive Action	Assign a network administrator to verify that IPS signature updates are completed successfully.
Preventive Action	Test updated signatures and IPS detection rules to ensure that the system can identify and block known malicious traffic.
Preventive Action	Restrict access to IPS configuration and update settings to authorised network administrators only.
Corrective Action	Immediately update the signature database when outdated signatures are identified.
Corrective Action	Investigate IPS logs and security alerts to identify any malicious traffic that may have bypassed the system.
Corrective Action	Review and correct IPS update settings to prevent the same problem from happening again.

These actions help ensure that the IPS can recognise known attack patterns and maintain effective network protection. They also reduce the possibility of malicious traffic reaching the company's internal network.

3.4 Risk Monitoring and Reporting

Continuous monitoring is important to ensure that the implemented risk mitigation strategies remain effective. LestariNw Sdn. Bhd. should establish monitoring and reporting activities to identify problems with the IPS signature database and respond to potential security incidents.
The following activities are proposed:

A. Risk Monitoring

The network administrator should regularly check the IPS signature database to ensure that updates are completed successfully. IPS logs and security alerts should also be reviewed to identify suspicious activities, failed updates and possible detection problems.

The company should perform regular checks on IPS configuration settings and test its detection and prevention functions. Any outdated signature database or update failure should be investigated and corrected immediately.

B. Risk Documentation

All identified risks and monitoring activities should be recorded in a **Risk Register**. The risk register should contain the following information:

- Identified risk and its description.
- Affected asset and vulnerability.
- Likelihood and severity ratings.
- Overall risk score and risk level.
- Risk mitigation strategies.
- Person responsible for managing the risk.
- Monitoring results and review dates.
- Current risk status and any corrective actions taken.

This documentation allows the company to track the identified risk and evaluate whether the implemented mitigation strategies are effective.

C. Risk Reporting

The network administrator should report IPS update failures, suspicious network activities and security incidents to the IT Security Manager. Serious incidents that may affect sensitive company information or business operations should be escalated to management for further action.
Regular risk reports should include the current risk level, monitoring findings, mitigation activities and any remaining security issues. This allows management to understand the company's security condition and make appropriate decisions.

D. Risk Review and Reassessment

The company should review the identified risk regularly and reassess its likelihood, severity and overall risk score after mitigation activities have been implemented. The assessment should also be reviewed whenever a security incident occurs or significant changes are made to the IPS configuration.

If the mitigation strategies are effective, the likelihood or severity rating may decrease. However, the company should continue monitoring the risk to ensure that the IPS remains effective against potential network threats.

Through continuous monitoring, documentation, reporting and reassessment, LestariNw Sdn. Bhd. can maintain effective IPS protection and improve its overall IT security posture.

Conclusion

In conclusion, the Risk Management Cycle helps LestariNw Sdn. Bhd. identify and manage the risk of an outdated IPS signature database. The risk assessment produces a score of 9, which is classified as HIGH and requires risk treatment. By implementing regular signature updates, monitoring IPS activities, maintaining a risk register and reporting security incidents, the company can reduce the likelihood of malicious traffic bypassing the IPS and strengthen the protection of its internal network and sensitive information.

TASK 4: ORGANIZATIONAL SECURITY POLICY

4.1 Security Policy: IPS Security Policy

4.1.1 Purpose

The purpose of this policy is to establish clear requirements for implementing, managing and maintaining the Intrusion Prevention System (IPS) at LestariNw Sdn. Bhd.

This policy aims to protect the company's network from malicious activities, unauthorised access and potential cyber threats. It also ensures that network traffic is continuously monitored and detected threats are prevented before they affect company systems and sensitive information.

4.1.2 Scope

This policy applies to all employees, IT personnel, network administrators and authorised users who access or manage the company's network.

It covers all IPS devices, remote access connections, internal network segments, company servers and network resources. All users must follow the security requirements when accessing or managing company resources, whether they are working inside or outside the office.

4.1.3 Policy Details

1. IPS must monitor network traffic and automatically block detected malicious activities.
2. IPS signature databases and detection rules must be updated regularly.
3. Security logs and alerts must be monitored to identify suspicious activities.
4. Only authorised IT personnel may access and modify IPS configurations.
5. IPS must be used together with firewalls, VPN and network segmentation to strengthen network protection.
6. Any IPS failure or security incident must be reported immediately.
7. IPS monitoring activities and security logs must be handled responsibly. Access to monitoring records must be restricted to authorised personnel to protect employee privacy and confidential company information.

4.1.4 Users and Responsibilities

Role	Responsibility
Management	Approves the policy and provides necessary resources.
IT Security Manager	Oversees IPS security and policy compliance.
Network Administrator	Configures, updates and monitors IPS devices.
Employees	Follow security requirements and report suspicious activities.

4.1.5 Policy Enforcement

All employees and authorised users must comply with this policy when accessing company network resources. The IT Security Manager is responsible for ensuring that the policy is followed and that any violation is properly investigated.

Unauthorised access to IPS devices, modification of security configurations and intentional disabling of IPS protection are considered policy violations. Such incidents must be reported to management, and appropriate corrective or disciplinary actions may be taken according to company rules.

This policy must be reviewed regularly and updated whenever there are significant changes to the company's network infrastructure, security requirements or identified threats.

4.2 Security Standard: NIST-Based IPS Security Standard

LestariNw Sdn. Bhd. adopts the National Institute of Standards and Technology (NIST) Special Publication 800-94, *Guide to Intrusion Detection and Prevention Systems (IDPS)*, as a technical reference for implementing and managing its IPS.

This standard supports the IPS Security Policy by establishing technical and operational requirements to ensure that IPS devices are properly configured, maintained and monitored. The following requirements are proposed for the company's network environment.

The technical and operational requirements in this section are adapted to the company's network environment with reference to NIST SP 800-94. These requirements serve as internal security guidelines for maintaining effective IPS protection.

4.2.1 Technical Requirements

Requirement	Description
IPS Deployment and Inspection	Install IPS at suitable network locations to monitor and inspect network traffic.
Threat Detection and Prevention	Identify suspicious activities and automatically block detected malicious traffic.
Signature Updates	Update IPS signatures regularly to detect the latest known threats.
Access Control	Restrict IPS configuration and management access to authorised IT personnel.
Logging and Monitoring	Record detected threats, blocked traffic and security alerts for monitoring and investigation.

4.2.2 Operational Requirements

1. **Regular Monitoring:** Network administrators must regularly review IPS logs, security alerts and system performance to identify suspicious activities.
2. **Signature Maintenance:** IPS signature updates must be checked regularly to ensure that updates are completed successfully and detection rules remain current.
3. **Configuration Management:** IPS configurations and access permissions must be reviewed periodically. Any changes must be performed by authorised personnel.
4. **Incident Management:** Detected threats, IPS failures and suspicious activities must be investigated, documented and reported to the IT Security Manager.
5. **Testing and Review:** IPS detection and prevention functions must be tested in a controlled environment to ensure that malicious traffic is blocked without unnecessarily disrupting legitimate network activities.
6. **Documentation:** IPS configurations, update records, monitoring results and security incidents must be documented for future reference and security reviews.

4.2.3 Compliance and Responsibilities

The Network Administrator is responsible for implementing and maintaining the technical requirements, while the IT Security Manager oversees compliance with this standard.

Regular reviews must be conducted to ensure that the IPS continues to operate effectively and supports the company's security policy. Any non-compliance or security weaknesses must be documented and corrected.

4.3 Security Procedure: IPS Implementation and Maintenance Procedure

This procedure provides step-by-step guidance for implementing, configuring, monitoring and maintaining the IPS at LestariNw Sdn. Bhd.

The Network Administrator is responsible for carrying out the IPS implementation, configuration, updating and monitoring activities. The IT Security Manager oversees the procedure, reviews security reports and ensures that all activities comply with the IPS Security Policy and Standard. Any major security incident must be escalated to management for further action.

Step 1: Identify Network Requirements

- Identify network segments, remote access connections and critical company servers that require IPS protection.
- Determine suitable IPS deployment locations based on the approved network architecture.
- Identify the network traffic and potential threats that need to be monitored.

Step 2: Install and Configure IPS

- Install IPS devices at the approved network locations.
- Connect the IPS inline to the relevant network traffic paths.
- Configure traffic inspection, threat detection and automatic blocking functions.
- Restrict IPS management access to authorised administrators.

Step 3: Update IPS Signatures

- Enable automatic signature updates or establish a regular update schedule.
- Verify that signature updates are completed successfully.
- Review detection rules to ensure they remain appropriate for known threats.
- Record update results and investigate any update failures.

Step 4: Test IPS Functionality

- Test whether the IPS can inspect network traffic correctly.
- Use a controlled testing environment to verify that simulated malicious traffic is detected and blocked.
- Confirm that legitimate network traffic can still reach authorised company resources.
- Document test results and correct any identified configuration problems.

Step 5: Monitor and Maintain IPS

- Review IPS security logs and alerts regularly to identify suspicious activities.
- Check IPS performance, system status and signature update records.
- Review IPS configurations and access permissions to ensure they remain secure.
- Investigate and correct any detected errors or system failures.

Step 6: Handle and Report Security Incidents

- Investigate suspicious activities and identify the affected network segments or systems.
- Determine the severity of the incident and check whether the IPS successfully blocked the threat.
- Record incident details, investigation findings and corrective actions.
- Report serious incidents to the IT Security Manager and escalate major incidents to management.

Step 7: Review and Improve

- Review IPS effectiveness based on monitoring results and security incidents.
- Update IPS signatures, detection rules and configurations when necessary.
- Evaluate whether corrective actions have successfully addressed identified security weaknesses.
- Update relevant documentation and ensure continued compliance with the IPS Security Policy and Standard.

Reference

National Institute of Standards and Technology. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)* (Special Publication 800-94). https://doi.org/10.6028/NIST.SP.800-94

RUBRIC CONTENT (COGNITIVE 10 %):

Attribute	Sub Attribute	Very Weak	Weak	Fair	Good	Very Good	Weightage	Mark Obtained
		1	2	3	4	5		
		TASK 1						
Problem solving	Problem identification	Provides minimal or incorrect answers, does not clearly identify a network defence technology or explanation is irrelevant.	Identifies network defence technology and gives a basic explanation, but the justification is limited and inconsistently related to the scenario.	Clearly choose appropriate network defence technology, provides a strong justification, and explains how it strengthens the company network with relations to scenario/example. Explanation is clear and technically accurate including: • Security function • How technology protects the company remote network • Why is selected technology appropriate.			**2**	

RUBRIC CONTENT (AFFECTIVE 20%):

Attribute	Sub Attribute	Very Weak	Weak	Fair	Good	Weightage	Mark Obtained
		1	2	3	4		
		TASK 2					
Problem solving	Analysis	Incomplete or incorrect answers, fails to propose a clear network architecture design.	Two (2) network architecture designs are provided, but some important components are missing. Basic flow is shown. Relevant components are included with basic functions. Basic comparison and recommendation.	Provides two (2) clear network architecture designs with relevant network components. Complete flow is clearly explained. Appropriate firewalls, IDS/IPS, or other controls are explained. Good comparison based on security and resources. .	Provides two (2) complete, logical, and technically appropriate designs with relations to the scenario. Communication flows are clearly illustrated and explained by remote users to protected company resources. Security controls are carefully selected, and their functions are clearly connected to identified threats and risks. Clear, evidence-based comparison considering security, risk, resources, limitations, and the company's requirements.	**3**	

		TASK 3						
		1	**2**	**3**	**4**	**5**	**Weightage**	**Mark Obtained**
Problem solving	Analysis (Depth and application of RMC to ONE selected risk)	☐ Identifies a risk that is unclear, inaccurate or not relevant to the selected technology. ☐ Provides minimal evaluation with little understanding of RMC.	☐ Identifies ONE relevant risk but provides a basic explanation. ☐ Evaluation covers some RMC elements but is incomplete or lacks justification.	☐ Clearly identifies and explains ONE relevant risk. ☐ Evaluates the risk using the main RMC stages, including likelihood, impact, mitigation and monitoring, but with limited depth.	☐ Provides a detailed evaluation of ONE relevant risk. ☐ Clearly justifies likelihood, impact and risk level, proposes suitable mitigation, and explains appropriate monitoring and reporting.	☐ Provides an excellent and comprehensive evaluation of ONE specific risk. ☐ Demonstrates strong understanding of RMC through a well-justified risk assessment, appropriate and practical mitigation, and a clear continuous reporting approach. ☐ The evaluation is strongly linked to the selected network defence technology and company scenario.	**2**	

		TASK 4					
		1	**2**	**3**	**4**	**Weightage**	**Mark Obtained**
Ethics	Work Ethics	Policy is unclear, incomplete, or lacks ethical focus. Shows limited understanding of professional and ethical standards.	Policy is basic or partly complete. Some ethical elements are present but lacks consistency or depth. Work ethics are moderately shown.	Policy is mostly clear and ethical. It covers most required areas. Shows good work ethics with minor lapses in completeness or clarity.	Policy is exceptionally comprehensive, well-structured, and ethically exemplary. All required areas are thoroughly addressed with outstanding clarity, professionalism, and accountability. Demonstrates exceptional understanding of ethical principles, promotes best practices, and reflects a strong commitment to responsible and professional conduct.	**1**	
	Work Ethics	Security standards are unclear, incomplete, or ignore ethical considerations. Policies do not reflect professional expectations.	Shows limited understanding of security standards. Ethical and professional aspects are weakly addressed.	Security standards are basic or partly complete. Some ethical and professional elements are present but lack consistency or depth.	Security standards are comprehensive, well-defined, and fully aligned with industry best practices and ethical principles. Required areas are thoroughly addressed with clear implementation guidelines, reflecting outstanding commitment to security, ethical conduct, and professional standards.	**1**	

Professionalism	Work professionalism	□ Procedures show minimal professionalism. □ Steps are unclear, incomplete, or handled carelessly	□ Procedures show limited professionalism. □ Some steps are followed, but responsibility and accountability are weak.	□ Procedures show moderate professionalism. □ Steps are mostly followed, responsibilities are understood, but minor lapses in completeness or clarity exist.	□ Procedures demonstrate exceptional professionalism and excellence. □ Steps are comprehensive, accurate, and executed with outstanding attention to detail. □ Shows accountability, ethical decision-making, and proactive adherence to security standards and best practices for professional conduct.	**1**	
Total Marks Earned							**/40**
Total Percentage (30%)							**/30%**